

Manual 49 — NIST AI RMF 1.0 + NIST AI 600-1 GenAI Operational Guide

****Status:**** CONTROLLED DEVELOPMENT

****Version:**** 0.3.0-draft

****Source verification date:**** 1 September 2026

****Canonical stage:**** 3 — controlled English training package

Purpose

Turn NIST AI RMF 1.0 and NIST AI 600-1 into a practical enterprise risk-management and assurance program that maps cleanly to Manual 46's universal governance spine without treating voluntary NIST guidance as law or certification.

Currency state

Official NIST and AIRC sources verified on 1 September 2026 identify AI RMF 1.0 as the published baseline and explicitly state that it is being revised. NIST AI 600-1 remains the published Generative AI Profile. Candidate freeze and publication remain fail-closed on a fresh revision-status check.

Stage-3 controlled package

- authoritative-source register with current NIST revision state;
- GOVERN/MAP/MEASURE/MANAGE operating architecture;
- GenAI risk-extension architecture;
- RAG/source-governance architecture;
- third-party/model-provider architecture;
- TEVV independence model;
- full controlled-English training modules;
- practical scenarios;
- control/evidence workbook;
- cross-framework non-equivalence rules;
- updated fail-closed preflight.

Practical operating model

Use the four NIST functions as a continuous system rather than a sequential checklist:

****GOVERN**** establishes accountability, policy, culture and risk tolerance.

****MAP**** establishes context, intended use, affected parties, dependencies and impact.

****MEASURE**** evaluates performance, risk, uncertainty and control effectiveness.

****MANAGE**** prioritizes and treats risk, monitors outcomes and responds to change.

Governance informs every other function throughout the lifecycle.

Evidence model

For each relevant AI RMF outcome or GenAI action, capture:

****Outcome/action → organizational interpretation → control objective → control activity → owner → evidence → test procedure → finding/exception → remediation → residual risk****

Publication gates

- ☒ Current NIST AI RMF revision status verified for controlled drafting.
- ☒ AI RMF operating architecture established.
- ☒ NIST AI 600-1 GenAI risk-extension architecture established.
- ☒ Playbook/AIRC current-state review completed.
- ☒ Controlled-English training modules complete.
- ☒ Practical scenarios and control/evidence workbook complete.
- ☐ Release-depth outcome/action mappings complete.
- ☐ Reverify NIST revision status at candidate freeze and publication.
- ☐ Technical/TEVV and cross-framework mapping review complete where genuinely required.
- ☐ Controlled localization and candidate tooling complete.
- ☐ Accessibility/artifact/provenance/security gates complete.

****Fail-closed:**** Manual 49 remains one controlled stage behind Manual 48. A published NIST revision before candidate freeze requires changed-scope reconciliation; retained genuine-human review evidence may not be fabricated.

Manual 49 — NIST AI RMF 1.0 + NIST AI 600-1 GenAI Training Modules

****Controlled English draft — Stage 3****

****Currentness baseline:**** 1 September 2026

Module 1 — NIST AI RMF as an operating system

Treat GOVERN, MAP, MEASURE and MANAGE as a continuous risk-management cycle. GOVERN is cross-cutting; MAP establishes context; MEASURE tests and evaluates; MANAGE prioritises and treats risk. Every function feeds the others as the system, provider, data, environment and use case change.

Evidence

- AI governance charter and risk policy;
- AI inventory and risk tiers;
- use-case/context records;
- evaluation/TEVV records;
- risk-treatment decisions;
- monitoring and incident evidence;
- change/revalidation records.

Module 2 — GOVERN: accountability and risk culture

Establish accountable ownership, decision rights, policies, risk tolerance, competence, lifecycle governance, third-party governance, exception handling and management reporting.

Control questions

- Who owns the AI system and its residual risk?
- Which roles can approve, restrict or suspend deployment?
- How are security, privacy, safety, model risk, legal/compliance and business perspectives integrated?
- What evidence shows governance actually operates?

Module 3 — MAP: purpose, context and impacts

Document intended purpose, deployment context, users, affected parties, data, dependencies, assumptions, benefits, foreseeable harms and misuse.

Evidence

- context/system diagram;
- intended-use statement;
- stakeholder/impact analysis;
- data and RAG source map;
- dependency inventory;
- misuse/abuse cases;
- limitations register.

Module 4 — MEASURE: evaluation and TEVV

Define acceptance criteria and test performance, robustness, security, privacy, uncertainty and control effectiveness under representative and adversarial conditions.

TEVV record

****claim** → metric/test → data/test set → environment/version → result → uncertainty/limitation → finding → remediation → retest******

Module 5 — MANAGE: risk treatment and lifecycle decisions

Prioritise identified risks and decide whether to deploy, restrict, remediate, accept, monitor, suspend or retire. Link every material risk to a disposition and owner.

Evidence

- treatment plan;
- deployment/exception decision;
- residual-risk acceptance;
- monitoring thresholds;
- remediation tracking;
- rollback/retirement plan.

Module 6 — Trustworthiness characteristics

Use NIST trustworthiness characteristics as design and evaluation considerations rather than a single composite score. Relevant considerations include validity/reliability, safety, security/resilience, accountability/transparency, explainability/interpretability, privacy enhancement and fairness with harmful bias managed where applicable.

Training rule

Trade-offs must be explicit. Improving one characteristic may create cost, performance, privacy or operational effects elsewhere.

Module 7 — NIST AI 600-1 GenAI profile

Use AI 600-1 as a GenAI companion profile to extend AI RMF outcomes/actions for generative-AI risks. Maintain source status: voluntary NIST profile, not law or certification.

Module 8 — Confabulation and information integrity

Risks

- plausible false output;
- invented citations/facts;
- stale or misleading information;
- downstream automation based on incorrect content.

Controls

- task-specific evaluation;
- source grounding/RAG where appropriate;
- confidence/limitation communication;
- human validation for consequential outputs;
- output verification against authoritative sources;
- monitoring of known failure classes.

Module 9 — RAG and knowledge-source governance

Control approved sources, provenance, authorisation, freshness, access inheritance, poisoning/tampering, sensitive data, retrieval quality and deletion/re-indexing.

Tests

- retrieval relevance;
- groundedness;
- poisoned-source resistance;
- unauthorised-source retrieval;
- stale-version detection;
- sensitive-data leakage.

Module 10 — Information security

Threat model the complete system: model, prompts, RAG, agents/tools, APIs, identities, secrets, providers, runtime and downstream actions.

Controls

- identity and least privilege;
- prompt/context boundary controls;
- tool/API restrictions;
- secrets protection;
- data validation;
- rate/resource limits;

- logging/monitoring;
- red teaming;
- incident response.

Module 11 — Privacy and sensitive data

Map collection, prompts, retrieval sources, logs, provider processing, retention and model/data reuse. Apply minimisation, purpose/authority controls, access restrictions, retention and privacy testing as applicable.

Module 12 — Human-AI configuration and overreliance

Assess where users may defer excessively to model output. Define training, review thresholds, independent checks, override mechanisms and monitoring of disagreement/override rates.

Module 13 — Harmful bias and representational risk

Where relevant to the use case, evaluate performance and impacts across appropriate populations/contexts. Avoid unsupported fairness claims and document limitations in data, metrics and interpretation.

Module 14 — Intellectual property and provenance

Track material source provenance and contractual/usage restrictions where relevant. Separate legal conclusions from technical provenance controls. Escalate legal ambiguity rather than encoding an unsupported rule into the model workflow.

Module 15 — Third-party model/provider risk

Maintain model/provider identity, material version, data-processing commitments, security/privacy controls, incident/change notification, continuity/exit provisions and revalidation triggers.

Change triggers

- provider/model replacement;
- capability expansion;
- changed safety policy;
- new training/data-use commitment;
- API/tool behavior change;
- changed geography/hosting;
- material performance shift.

Module 16 — Red teaming and adversarial evaluation

Scale adversarial testing to materiality. Include prompt injection, jailbreak/unsafe content where relevant, data leakage, RAG poisoning, privilege/tool abuse, denial/resource exhaustion, misleading outputs and containment/recovery.

Module 17 — Monitoring and KRIs

Monitor operational performance, safety/security events, evaluation drift, provider changes, user complaints, override patterns, policy denials, incidents and unresolved findings.

Example KRIs

- evaluation failure rate;
- groundedness/citation failure;
- security-policy denials;
- high-impact human overrides;
- unresolved critical findings;
- provider changes awaiting revalidation;
- AI incidents/near misses.

Module 18 — Incident response

Integrate AI/GenAI incidents into enterprise incident response. Preserve model/provider/version, prompts/context, RAG/tool evidence, affected users/data, containment actions and root-cause/remediation records.

Module 19 — Change management and revalidation

Material changes to model, prompt/system instructions, provider, RAG sources, tools, permissions, data, evaluation assumptions, use case or population trigger proportionate reassessment and revalidation.

Module 20 — Independent challenge and assurance

Scale independence to risk. Developer self-testing may be adequate for low-risk routine use; high-impact systems may require independent internal review, specialist red teaming or external assurance where applicable.

Assurance rule

NIST does not certify implementation through AI RMF alignment. Assurance claims must describe the actual scope, evidence, tests, limitations and residual risk.

Module 21 — Cross-framework mapping

Map NIST outcomes/actions to Manual 46 common controls and, where useful, to EU AI Act, ISO/IEC 42001 and Singapore governance. Every mapping records relationship type and differences. Similar language does not imply identical obligations.

Module 22 — 30/60/90-day enterprise implementation

30 days

- establish governance ownership;
- inventory AI/GenAI systems;
- define risk tiering;
- document highest-risk use cases and dependencies;
- establish evaluation/evidence repository.

60 days

- complete MAP records;
- implement TEVV/evaluation plans;
- establish provider/RAG controls;
- define monitoring and incident procedures;

- close critical control gaps.

90 days

- execute independent challenge for material systems;
- test revalidation/change process;
- report KRIs and residual risk;
- complete remediation cycle;
- institutionalise continuous GOVERN/MAP/MEASURE/MANAGE feedback.

Completion standard

A learner completes Manual 49 when they can take an AI/GenAI use case through GOVERN, MAP, MEASURE and MANAGE, produce auditable evidence and testing, treat GenAI-specific risks through NIST AI 600-1, and explain limitations without claiming legal compliance or certification from NIST alignment.

Manual 49 — Practical Scenarios

Scenario 1 — Enterprise GenAI assistant

A company deploys a GenAI assistant over internal policies and customer procedures.

GOVERN

Assign owner, risk tier, policies, provider oversight and decision rights.

MAP

Document users, intended purpose, RAG sources, affected data, foreseeable misuse and dependencies.

MEASURE

Test retrieval relevance, groundedness, hallucination, sensitive-data leakage and unsafe responses.

MANAGE

Set deployment limits, human escalation, monitoring thresholds, provider-change triggers and incident procedures.

Scenario 2 — High-impact hiring support

A GenAI system summarises candidate materials and proposes interview priorities.

Learners must identify human-AI configuration risk, overreliance, performance/fairness concerns where relevant, privacy, vendor/data issues and evidence needed for independent challenge. The final decision authority must remain explicit.

Scenario 3 — RAG poisoning

An internal knowledge base contains a malicious or incorrect document that instructs the model to ignore policy and expose sensitive information.

Required controls

- controlled ingestion and source provenance;
- content trust classification;
- retrieval/access controls;
- prompt/context isolation;
- adversarial testing;
- source removal/re-indexing;
- incident reconstruction.

Scenario 4 — Provider silently changes the model

A SaaS vendor changes the underlying model and safety behavior without a customer release process.

Learners define the revalidation trigger, contract/change-notification requirement, regression test set, monitoring and deployment disposition until acceptable evidence exists.

Scenario 5 — Customer-facing financial explanation

A GenAI system explains financial products but cannot give binding investment advice or approve transactions.

Learners MAP intended/forbidden uses, MEASURE false/confabulated claims and MANAGE escalation, disclosures and monitoring.

Scenario 6 — Red-team finding

A red team demonstrates that indirect prompt injection can cause the system to exfiltrate content from an internal RAG source.

Learners must record the finding, severity, containment, technical remediation, retest, residual risk decision and conditions for return to service.

Scenario 7 — Automation bias

Operators accept almost every GenAI recommendation even though policy requires independent judgment.

Learners propose reviewer training, forced independent checks, override/disagreement metrics and investigation thresholds.

Scenario 8 — Incident after harmful output

A public GenAI service generates dangerous guidance and the incident cannot initially be reproduced because the exact model version and context were not retained.

Learners identify evidence/provenance failures, IR improvements and minimum logging/version-control requirements.

Scenario 9 — Executive risk decision

A dashboard shows one system with strong benchmark scores but unresolved privacy and provider-change controls. Another has lower accuracy but strong human review and bounded use.

Learners explain why AI risk cannot be reduced to one performance score and produce a documented MANAGE decision.

Scenario 10 — Cross-framework claim

A manager says: “We follow NIST AI RMF, so we comply with the EU AI Act and are ISO/IEC 42001 certified.”

Learners must reject the claim and create a qualified mapping showing common controls, framework-specific obligations/evidence and different legal/standards status.

Manual 49 — NIST AI RMF + GenAI Control and Evidence Workbook

| ID | Function/domain | Control objective | Minimum evidence | Test / assurance method |

|---|---|---|---|---|

| N-AI-01 | GOVERN | Assign accountable AI ownership and decision rights | charter, RACI, approvals | sample decisions and ownership |

| N-AI-02 | GOVERN | Maintain AI/GenAI inventory and risk tier | inventory, tier rationale | reconcile against procurement/cloud/repos |

| N-AI-03 | GOVERN | Establish policy, risk tolerance and exceptions | policy, standards, exceptions | inspect exceptions and expiry/remediation |

| N-AI-04 | GOVERN | Govern model/provider and third parties | assessment, contract, change notices | sample material provider changes |

| N-AI-05 | MAP | Document intended purpose and prohibited/misuse cases | use-case statement, misuse analysis | compare production use to approved purpose |

| N-AI-06 | MAP | Identify actors, users and affected parties | stakeholder map | sample impacts and escalation paths |

| N-AI-07 | MAP | Map data, RAG and technical dependencies | architecture, lineage/source map | trace sampled data/retrieval flows |

| N-AI-08 | MAP | Record assumptions, limitations and foreseeable harms | limitations/risk register | challenge assumptions against evidence |

| N-AI-09 | MEASURE | Define measurable acceptance criteria | evaluation plan, thresholds | reproduce selected tests |

| N-AI-10 | MEASURE | Preserve test/version provenance | model/provider version, test config | verify reproducibility |

| N-AI-11 | MEASURE | Test robustness and adversarial behavior | red-team/test report | retest remediated findings |

| N-AI-12 | MEASURE | Evaluate security/privacy risks | security/privacy tests | attack/leakage sampling |

| N-AI-13 | MEASURE | Evaluate human overreliance where relevant | user study/override metrics | analyze disagreement/override rates |

| N-AI-14 | MANAGE | Tie material risks to treatment decisions | treatment plan, owners, due dates | sample open/closed risks |

| N-AI-15 | MANAGE | Establish deployment/exception gate | decision record, residual risk | verify authority/evidence basis |

| N-AI-16 | MANAGE | Monitor KRIs, incidents and drift | dashboard, alerts, incident log | sample alert-to-action trace |

| N-AI-17 | MANAGE | Trigger revalidation after material change | trigger matrix, change tickets | sample model/provider/RAG changes |

| N-GEN-01 | GenAI | Control confabulation/information integrity | groundedness/factuality tests | sample high-impact responses |

| N-GEN-02 | GenAI | Govern RAG source provenance and access | allowlist, lineage, access rules | poison/unauthorized retrieval tests |

| N-GEN-03 | GenAI | Control sensitive-data leakage | DLP/privacy config and tests | adversarial leakage testing |

| N-GEN-04 | GenAI | Manage harmful/unsafe outputs | policy, filters, evaluations | safety test set / red team |

| N-GEN-05 | GenAI | Govern provider/model changes | version/change register | regression/revalidation sampling |

| N-GEN-06 | GenAI | Preserve content/source provenance where relevant | source/citation metadata | trace selected output to sources |

| N-TEVV-01 | Assurance | Scale independent challenge to materiality | assurance plan, reviewer independence | verify reviewer separation/competence |

| N-IR-01 | Incident | Reconstruct AI/GenAI incidents | version, prompt/context, RAG/tool logs | tabletop or incident reconstruction |

| N-XW-01 | Crosswalk | Prevent false equivalence | mapping rationale/caveats | review claims against source status |

Evidence register

For each control record:

- system/use case;
- control ID and owner;
- evidence location/date;
- model/provider/tool version;
- test procedure and test data;
- result and uncertainty/limitation;
- finding/exception;
- remediation owner/date;
- residual-risk decision;

- next revalidation date.

GOVERN-MAP-MEASURE-MANAGE case worksheet

GOVERN

Who owns risk? What policy/risk tolerance applies? What provider/third-party dependencies exist?

MAP

What is the intended use? Who is affected? What data/RAG/tools/dependencies exist? What harms/misuse are foreseeable?

MEASURE

Which claims must be tested? What metrics, test sets and adversarial cases apply? What uncertainty remains?

MANAGE

What risks require treatment? Who accepts residual risk? What monitoring, change triggers, incident and rollback controls apply?

Release caveat

This workbook operationalises voluntary NIST AI RMF / AI 600-1 guidance. Completion does not constitute NIST certification and does not by itself establish compliance with law or another standard.